

Universidad Mariano Gálvez de Guatemala
Centro Universitario de Puerto Barrios
Facultad de Ingeniería en Sistemas
Proyecto de Graduación II
Ing. Juan Pablo Escobar



Presentación del Incremento 1.

Seguridad y calidad del Sprint 1, ejecutado del 22 al 29 de agosto de 2026 sobre el proyecto BayStream.

Carlos Giovanni Martínez Aldana 0909-22-19157

Puerto Barrios, Izabal 29 de agosto de 2026

Índice

I. Introducción

A. Propósito del reporte

El presente documento cumple una doble función. Por una parte, presenta el primer incremento del producto: qué se construyó, con qué esfuerzo y con qué evidencia verificable. Por otra, evalúa la seguridad y la calidad de lo construido, de modo que el avance no se juzgue únicamente por su funcionalidad visible.

Esa segunda función merece una precisión inicial. Un reporte de avance que solo enumera funcionalidades entregadas es fácil de escribir y difícil de refutar, porque no se compromete con ningún criterio de verificación. Este reporte adopta el compromiso contrario: declara el criterio antes de aplicarlo, documenta lo que no se hizo con el mismo detalle que lo que sí, y expone los hallazgos de seguridad incluyendo aquellos que resultan desfavorables al propio proyecto.

El incremento se desarrolló entre el 22 y el 29 de agosto de 2026, sobre el Sprint Backlog presentado el 22 de agosto y el Product Backlog aprobado el 15 de agosto.

B. Definición de términos

Se definen operacionalmente los términos empleados a lo largo del reporte, de modo que su interpretación no dependa del criterio del lector.

Tabla 50.

Definición de términos del reporte de incremento

Término	Definición operacional
Incremento	Suma de los elementos del Product Backlog completados durante un sprint, en condición utilizable y verificada contra la Definición de Terminado. En este reporte, el conjunto de las cinco funcionalidades entregadas entre el 22 y el 29 de agosto de 2026.
Definición de Terminado	Lista de condiciones que una tarea debe cumplir para considerarse completada. Es el criterio de verificación empleado en este reporte; su cumplimiento se documenta en la Tabla 54.
Confirmación (commit)	Registro inmutable de un conjunto de cambios en el repositorio, identificado por un resumen criptográfico. Constituye la evidencia verificable de que una tarea fue efectivamente implementada.
Evaluación de línea base	Revisión estática del código fuente contra un catálogo de referencia, cuyo propósito es establecer el estado inicial de seguridad y no certificar su ausencia de defectos.
OWASP Top 10:2025	Catálogo de los diez riesgos de seguridad más críticos en aplicaciones web, publicado por la Open Worldwide Application Security Project Foundation. Es la versión vigente del catálogo web.
OWASP Mobile Top 10 2024	Catálogo equivalente para aplicaciones móviles, cuya versión final vigente corresponde al año 2024. Se aplica al cliente Android de BayStream.
Severidad	Clasificación del impacto potencial de un hallazgo, expresada en cuatro grados: crítica, alta, media y baja. No equivale a probabilidad de explotación.

Fuente: elaboración propia, con base en Schwaber y Sutherland (2020) para los términos de Scrum y en OWASP Foundation (2024, 2025) para los términos de seguridad.

C. Limitaciones del reporte

Tres limitaciones acotan el alcance de lo que aquí se afirma, y conviene declararlas antes de presentar los resultados.

- La evaluación de seguridad es una revisión estática del código fuente. No constituye una prueba de penetración ni certifica la ausencia de vulnerabilidades: establece una línea base sobre la cual medir el avance posterior.
- El equipo de desarrollo es unipersonal. Las métricas de velocidad y capacidad no son extrapolables a equipos de mayor tamaño, y la verificación del incremento carece de la revisión cruzada que aportaría un segundo desarrollador.
- La validación funcional se ejecutó sobre un único archivo BAPLIE real anonimizado. Aunque su volumen es representativo, un solo archivo no cubre la variabilidad de formatos que emiten distintas navieras.

El presente reporte no incorpora figuras. La evidencia visual del incremento se presenta en el tablero de cierre del sprint, entregado como documento independiente.

II. Método

A. Protocolo de ejecución del sprint

La ejecución siguió un orden de ataque por riesgo decreciente y no por numeración de tareas. El criterio es que aquello que puede invalidar un requerimiento completo debe fallar el primer día del sprint y no el último, cuando ya no hay margen para replantear.

En consecuencia, la primera tarea ejecutada fue la verificación del paquete de generación de PDF en las tres plataformas, de la cual dependía la viabilidad entera de RF-025. La segunda fue el trazado del perfil longitudinal del buque, por tratarse de render geométrico sin precedente en la base de código. Los bloques de menor incertidumbre se ejecutaron después.

Se estableció además una regla de separación de responsabilidades: la escritura del código se delegó a un agente de codificación, mientras que la totalidad de las operaciones sobre el repositorio —preparación, confirmación y publicación de cambios— fue ejecutada por el autor. La razón es que el historial del repositorio constituye evidencia empírica del trabajo de graduación, y su autoría debe corresponder a quien lo defiende.

B. Criterio de verificación del incremento

El incremento se verificó contra la Definición de Terminado establecida al abrir el sprint. Se trata de una lista de condiciones fijadas antes de comenzar el trabajo, precisamente para que el criterio de aceptación no pudiera ajustarse a posteriori en función de lo que resultara conveniente.

Una precisión sobre la condición de análisis estático: exige que no se introduzcan advertencias nuevas, no que el proyecto alcance cero advertencias absolutas. La distinción es deliberada. El proyecto arrastra advertencias preexistentes cuya corrección constituye trabajo de refactorización, ajeno al objetivo del sprint. Exigir cero absoluto habría desviado esfuerzo del incremento hacia una limpieza que tiene su propia tarea calendarizada.

C. Procedimiento de la evaluación de seguridad

La evaluación se ejecutó sobre el estado del código al cierre del sprint, correspondiente a la confirmación 80dde67, mediante inspección dirigida del código fuente. El procedimiento consistió en localizar en el árbol del proyecto los puntos donde cada categoría de los catálogos de referencia podría materializarse, y verificar el estado de cada uno.

La decisión metodológica de mayor consecuencia fue aplicar dos catálogos en lugar de uno. BayStream se distribuye en tres clientes —

Windows, Android y navegador— desde una sola base de código. El catálogo web resulta aplicable al cliente de navegador, cuyo paquete es público e inspeccionable; el catálogo móvil resulta aplicable al cliente Android, cuyo artefacto es un archivo instalable sujeto a riesgos de almacenamiento local y de protección del binario. Aplicar solo uno de los dos habría dejado sin evaluar una parte del producto.

Cada hallazgo se clasificó en cuatro grados de severidad y se le asignó un tratamiento explícito: mitigación inmediata, acotamiento provisional o diferimiento justificado a una tarea calendarizada. Ningún hallazgo quedó sin tratamiento asignado.

III. Resultados

A. Elementos entregados en el incremento

El incremento comprende 5 elementos del Product Backlog, que suman 18 puntos de historia y 9.75 horas netas de desarrollo. Se describen a continuación por el valor que aportan al planificador de estiba, y no por su implementación técnica.

Tabla 51.*Elementos del Product Backlog entregados en el Incremento 1*

Id	Elemento	Prioridad	Pts	Valor entregado al usuario
RF-012	Indicadores de peso por nivel (tier)	SHOULD	3	El planificador ve el peso acumulado de cada nivel sin salir del plano de bahía, y el nivel que supera el límite de apilamiento se resalta con el color semántico de advertencia.
RF-020	Estado vacío del buscador con estadísticas	COULD	2	Al abrir el buscador sin escribir nada, el planificador ve las cinco navieras y los cinco puertos con más carga del viaje, ordenados por frecuencia real y tocables para lanzar la búsqueda.
RF-025	Exportación de reporte en PDF	SHOULD	5	El viaje completo se exporta como un reporte PDF con portada de métricas, una página por bahía con el mismo esquema cromático de la pantalla, y la tabla de contenedores ordenada por coordenada de estiba.
RF-026+	Perfil longitudinal del buque	SHOULD	5	El planificador lee la carga del buque completo en una sola vista, alterna entre ocupación y peso, y toca cualquier bahía para saltar directamente a su plano de detalle.
RF-033	Exportación de datos en formatos estándar	SHOULD	3	El viaje se exporta en CSV —con marca de orden de bytes para que Excel respete los acentos— y en JSON derivado del propio modelo de dominio, sin serialización paralela.
	Total		18	18 tareas · 9.75 h de 12 h de capacidad · holgura 2.25 h

Fuente: elaboración propia, con base en el Product Backlog aprobado el 15 de agosto de 2026 y el registro de ejecución del sprint.

B. Trazabilidad con el repositorio

Cada tarea del sprint termina en una confirmación verificable del repositorio. Esta correspondencia es lo que permite auditar el incremento: no se afirma que una funcionalidad exista, se señala dónde está su implementación. El historial se comprobó contra la rama remota el 25 de agosto de 2026.

Tabla 52.

Trazabilidad entre las tareas del sprint y las confirmaciones del repositorio

Confirmación	Mensaje	Tareas	Requerimiento
52ec4da	RF-025: verificar paquete PDF en las tres plataformas	T-08	RF-025
f5c84fb	RF-026+: anadir perfil longitudinal con ocupacion y peso	T-17, T-18	RF-026+
5b260d8	RF-012: anadir indicadores de peso por nivel	T-01 ... T-04	RF-012
e0f41a6	RF-033: exportar viaje en CSV y JSON	T-13 ... T-16	RF-033
c9e48b2	RF-025: generar y guardar reporte PDF completo	T-09 ... T-12	RF-025
51e8bb6	RF-026+: integrar perfil longitudinal con Bay Plan	T-19, T-20	RF-026+
80dde67	RF-020: ordenar navieras y puertos por frecuencia	T-21	RF-020

Fuente: historial del repositorio del proyecto, verificado el 25 de agosto de 2026.

C. Calidad del incremento

La calidad se expresa en dos planos: la distribución del esfuerzo realmente ejecutado y el cumplimiento de las condiciones de terminación.

Tabla 53.

Distribución del esfuerzo ejecutado por tipo de tarea

Tipo de tarea	Tareas	Horas	Proporción del esfuerzo
Dominio	1	0.5	5 %
Interfaz	11	6.5	67 %
Prueba	2	0.5	5 %
Infraestructura	2	1	10 %
Datos	2	1.25	13 %
Total	18	9.75	100 %

Fuente: elaboración propia, con base en el registro de ejecución del sprint.

Tabla 54.

Verificación del incremento contra la Definición de Terminado

Condición de la Definición de Terminado	Cumple	Evidencia
Satisface los criterios de aceptación en los tres clientes soportados	Sí	Compilaciones verificadas en Windows, Android y Web para cada bloque de tareas.
Respeto la separación de capas de la arquitectura limpia	Sí	Las entidades del dominio permanecen en Dart puro; los servicios nuevos se ubicaron en la capa de datos.
La suite de pruebas automáticas permanece en verde	Sí	De 21 pruebas al abrir el sprint a 31 al cerrarlo, sin regresiones.
El análisis estático no introduce advertencias nuevas	Sí	Cero advertencias nuevas. Persisten 49 advertencias preexistentes, declaradas y diferidas.

Condición de la Definición de Terminado	Cumple	Evidencia
Verificada contra un archivo BAPLIE real, no solo con datos sintéticos	Sí	Validación con CORPUS_A01.edi: 977 contenedores en 27 bahías.
Confirmación descriptiva que referencia el requerimiento	Sí	Las 7 confirmaciones citan su requerimiento en el mensaje.

Fuente: elaboración propia, con base en la verificación ejecutada al cierre de cada bloque de tareas.

Sobre la dependencia añadida conviene una nota. Durante RF-025 se evaluó la incorporación de un segundo paquete para habilitar la hoja de compartir del sistema Android. Se descartó: el paquete ya presente en el proyecto resolvía el guardado en las tres plataformas, y el candidato exigía una versión del lenguaje incompatible con la del proyecto además de introducir código nativo que habría obligado a repetir la verificación de las tres compilaciones. El incremento se completó con una sola dependencia añadida.

D. Seguridad: hallazgos de la evaluación

La evaluación identificó 7 hallazgos, de los cuales 3 corresponden a severidad crítica o alta. Se presentan ordenados por severidad descendente, con su correspondencia en ambos catálogos y el tratamiento asignado.

Tabla 55.*Hallazgos de la evaluación de seguridad de línea base*

#	Hallazgo	Severidad	Top 10:2025	Mobile 2024	Tratamiento
H-01	Sin reglas de autorización bajo control de versiones	Crítica	A01:2025	M3	Resuelto · publicado y verificado 25-ago
H-02	Sin autenticación; creación y actualización anónimas	Alta	A01, A07	M3	Acotado; resolución en TC-03
H-03	Reglas de prueba EXPIRADAS el 17-ago: acceso denegado durante ocho días	Crítica	A02:2025	M8	Resuelto · reglas sin expiración, 25-ago
H-04	Credenciales de Firebase escritas en duro en el código fuente	Media	A02:2025	M1	Declarado; resolución en TC-04
H-05	Texto crudo de excepciones expuesto en mensajes de interfaz	Baja	A10:2025	M6	Diferido a TC-01
H-06	Sin registro de eventos ni alertas	Baja	A09:2025	—	Diferido a TC-03
H-07	Sin análisis automatizado de vulnerabilidades en dependencias	Baja	A03:2025	M2	Diferido a TC-03

Fuente: elaboración propia, con base en la inspección del código fuente en la confirmación 80dde67, evaluado contra OWASP Foundation (2024, 2025). La mitigación de H-01 y H-02 se confirmó en 89bdb2c.

1. Una corrección que conviene declarar

Esta evaluación se ejecutó sin poder leer las reglas de autorización vigentes, precisamente porque no estaban en el repositorio. Sus

valores se infirieron del comportamiento por defecto de la plataforma. Al acceder posteriormente a la consola de administración se comprobó que dos de las tres inferencias eran incorrectas, y ambas se han corregido en la tabla anterior.

La primera afirmaba que la colección de viajes admitía borrado anónimo. Es falso: las reglas vigentes ya negaban esa operación de forma explícita en ambas colecciones. La operación irreversible nunca estuvo expuesta, lo que rebaja la severidad de ese hallazgo de crítica a alta. La segunda estimaba que las reglas provisionales caducarían transcurridos treinta días desde la creación del proyecto. La ventana real era de tres días y había vencido ocho días antes de la observación.

El error tiene una consecuencia metodológica que merece registrarse, porque no es un descuido aislado sino la manifestación directa del primer hallazgo. La ausencia de reglas bajo control de versiones significa, en la práctica, que la configuración de seguridad no es revisable; y una configuración no revisable produce evaluaciones que infieren en lugar de verificar. La evaluación se equivocó exactamente en aquello que el hallazgo advertía que no podía comprobarse. Ningún razonamiento teórico sobre la conveniencia de versionar la configuración de seguridad resulta tan concluyente como este episodio.

Corresponde también reconocer lo que la inferencia subestimó. Las reglas existentes negaban el borrado y acotaban el acceso a las dos

colecciones efectivamente utilizadas. Estaban mejor diseñadas de lo que la evaluación supuso.

2. Los hallazgos de mayor severidad

Dos hallazgos comparten una raíz común y conviene explicarla con precisión, porque de ella depende su correcta interpretación.

La aplicación no incorpora autenticación. Esto no es un descuido: la autenticación está deliberadamente fuera del alcance comprometido para el curso, según consta en el Product Backlog. El problema no es la ausencia en sí, sino su consecuencia no evaluada hasta ahora: al no existir autenticación y al no haber reglas de autorización bajo control de versiones, la colección de viajes admite escritura y borrado sin credencial alguna. La operación de borrado es la de mayor consecuencia, porque es irreversible y ningún requerimiento del ERS la necesita.

La mitigación adoptada consiste en incorporar al repositorio un archivo de reglas de autorización que permite lectura, creación y actualización sobre la colección de viajes, pero niega el borrado de forma explícita, y cierra el acceso a toda colección no declarada. Esta medida no convierte la aplicación en segura, y no se presenta como tal. Hace tres cosas verificables: elimina la operación destructiva, reduce la superficie expuesta y sitúa el control bajo control de versiones, donde puede ser revisado y explicado.

La redacción de esa regla obligó a una segunda decisión que conviene documentar, y cuyo primer intento fue erróneo. La cláusula general de denegación alcanzaba también a la colección donde escriben las pantallas de instrumentación empleadas para medir la hipótesis H5. Las mediciones ya obtenidas no corrían riesgo —están confirmadas en el repositorio—, pero la instrumentación habría quedado inhabilitada para repetirlas.

La regla correctiva se redactó inicialmente para permitir únicamente la creación de mediciones y negar toda modificación posterior. Esa formulación habría inhabilitado la medición por completo. El protocolo de medición de latencia no registra un dato aislado: es un intercambio en dos fases sobre un mismo documento, en el que un cliente emisor lo crea marcado como no respondido y un cliente receptor lo cierra marcándolo como respondido y añadiendo su tiempo de proceso. La latencia de ida y vuelta se obtiene de la diferencia entre ambos instantes. Negar la modificación habría impedido la segunda fase, y cada evento habría terminado por tiempo de espera agotado.

La regla finalmente adoptada autoriza esa transición y ninguna otra. Permite modificar un documento solo si está marcado como no respondido, solo para marcarlo como respondido, solo si el tiempo de proceso es un valor numérico, y solo si los campos afectados son exactamente esos dos. El resultado es una garantía más precisa que la pretendida en el primer intento: el instante de emisión, la condición experimental y el número de evento —los tres campos que habría que alterar para falsear un resultado de latencia— resultan inmutables

desde su creación, y una medición ya cerrada no admite una segunda modificación, de modo que tampoco es posible repetir el cierre hasta obtener una cifra favorable.

Este episodio ilustra un riesgo propio de las reglas de autorización declarativas: una cláusula general de denegación puede inhabilitar funcionalidad legítima de forma silenciosa, sin producir un error de compilación ni una prueba fallida. Se detectó porque la regla se contrastó contra el código de la instrumentación antes de publicarse, y no después.

El tercer hallazgo resultó ser el más grave de todos, y su severidad solo pudo establecerse al observar las reglas vigentes. Éstas condicionaban toda lectura y escritura a que la fecha de la solicitud fuese anterior al 17 de agosto de 2026. En el momento de la observación habían transcurrido ocho días desde ese vencimiento, con la totalidad de los accesos denegados. El panel de uso del servicio lo confirma de forma independiente: cero operaciones de lectura y cero de escritura durante el período comprendido entre el 18 y el 24 de agosto.

No se trataba, por tanto, de un riesgo futuro sino de una interrupción ya ocurrida. La sincronización en tiempo real llevaba ocho días inoperante sin que nadie lo advirtiera, y la razón de que pasara inadvertida es instructiva: ninguna de las cinco funcionalidades entregadas en este incremento utiliza la base de datos remota. El análisis de archivos, los indicadores de peso, el perfil longitudinal y las

tres exportaciones operan íntegramente sobre datos en memoria. Una interrupción en un servicio del que el trabajo en curso no depende puede prolongarse indefinidamente sin producir señal alguna.

La publicación de las reglas versionadas resolvió la interrupción. Las nuevas no contienen cláusula de expiración, de modo que la situación no puede repetirse por esta causa.

E. Seguridad: controles adecuados y alcance diferido

Una evaluación que solo reporta defectos ofrece una imagen distorsionada. Se documentan también los controles verificados como adecuados.

Tabla 56.

Controles de seguridad verificados como adecuados

Control	Evidencia	Top 10	Mobile
Validación de entrada del parser BAPLIE	Indexación con verificación de límites, int.tryParse para coordenadas, excepciones explícitas para contenido vacío o sin segmentos.	A05:2025	M4
Higiene de secretos en el control de versiones	.gitignore excluye .env, .env.* y google-services.json. Ningún archivo con secretos aparece entre los rastreados.	A02:2025	M1
Fijación exacta de dependencia crítica	pdf: 3.12.0 fijado sin rango. Once dependencias directas, todas de pub.dev, sin deriva de pubspec.lock.	A03:2025	M2

Fuente: elaboración propia, con base en la inspección del código fuente en la confirmación 80dde67.

Igualmente se declara lo que la evaluación no cubrió. Omitir esta declaración permitiría que el reporte se leyera como más exhaustivo de lo que es.

Tabla 57.

Actividades de seguridad diferidas a la tarea de cierre TC-03

Actividad no ejecutada	Razón del diferimiento
Análisis dinámico (DAST) contra el despliegue	Requiere un entorno desplegado y estable; el proyecto de producción se crea en TC-04.
Auditoría del binario Android para protecciones de empaquetado (M7)	Exige herramientas de ingeniería inversa fuera del alcance declarado del curso.
Análisis de composición de software sobre dependencias transitivas	Exige integración de una herramienta de inventario en el flujo de construcción.

Fuente: elaboración propia. Las tres actividades constituyen el alcance de la tarea TC-03, calendarizada del 18 al 24 de octubre de 2026.

1. Verificación funcional de las reglas publicadas

Las reglas de autorización constituyeron el único control de este incremento que no pudo verificarse ejecutándolo durante el sprint: no existe compilador que las valide ni prueba automatizada que las cubra. Se contrastaron por tanto contra el protocolo real de medición, con el cliente Android actuando como receptor y el cliente Web como emisor, en una serie de tres eventos.

Tabla 58.*Verificación funcional de las reglas de autorización publicadas*

Evento	Emisión (ms)	Recepción (ms)	Ida y vuelta	Proceso B (ms)
1	1787699349812	1787699351135	1 323 ms	2.614
2	1787699356147	1787699356950	803 ms	0.110
3	1787699361956	1787699362921	965 ms	0.086

Fuente: verificación ejecutada el 25 de agosto de 2026 sobre las reglas publicadas ese mismo día.

Los tres eventos se cerraron correctamente. La evidencia es concluyente por construcción del propio código de instrumentación: la fila de resultados se emite únicamente después de que el observador del emisor detecta la marca de respuesta, de modo que un instante de recepción con valor demuestra que la actualización del receptor fue aceptada por las reglas vigentes.

Durante la activación del receptor se registraron tres denegaciones de permiso sobre documentos de corridas anteriores que habían quedado sin cerrar. No afectaron a los eventos nuevos. La explicación más probable es que la regla rechazara un segundo cierre sobre documentos ya cerrados —esto es, la garantía de no reabrir una medición operando por sí misma—, si bien no se conservó traza suficiente para descartar que se trate de documentos con una estructura que la regla no contempla. La colección se revisó posteriormente desde la consola y no quedaba ningún documento sin cerrar.

IV. Discusión

A. El ajuste de alcance y lo que revela del ERS

Al abrir el sprint se comprobó que uno de los cinco elementos comprometidos, RF-020, ya se encontraba implementado desde febrero de 2026. El Sprint Backlog entregado el 22 de agosto lo incluía con tres tareas y una hora de esfuerzo estimado.

Tabla 59.

Ajuste del alcance del sprint y su justificación

Aspecto	Lo planificado	Lo ejecutado
Tareas de RF-020	T-05, T-06 y T-07 · 1.0 h	Retiradas. La funcionalidad ya existía desde la confirmación cb1861f del 2 de febrero de 2026.
Tarea sustituta	No prevista	T-21 · 0.25 h. Corrige un defecto real detectado en esa misma revisión: el estado vacío tomaba las cinco primeras navieras en orden de inserción y no las cinco más frecuentes.
Efecto sobre el sprint	21 tareas · 10.5 h	18 tareas · 9.75 h. La numeración conserva los huecos a propósito, para que coincida con el documento entregado.

Fuente: elaboración propia, con base en la revisión del código previa a la apertura del sprint.

Este es el tercer caso de la misma naturaleza en el proyecto: el ERS también consigna RF-011 y RF-014 como propuestos cuando el código demuestra lo contrario. Tres casos ya no constituyen un descuido aislado

sino un patrón, y su interpretación honesta es que el ERS dejó de actualizarse al ritmo del desarrollo. La corrección del documento y su notificación al asesor quedan registradas como tarea pendiente.

Vale la pena señalar el efecto positivo del hallazgo: la revisión previa a la apertura del sprint evitó reimplementar funcionalidad existente y, en el proceso, detectó un defecto genuino que había pasado inadvertido durante seis meses. La prueba escrita para T-21 falla contra la implementación anterior, lo que la convierte en una prueba de regresión efectiva y no en una que se limita a confirmar el comportamiento vigente.

B. Implicación de los hallazgos para la hipótesis H4

La hipótesis H4 sostiene que el enfoque multiplataforma reduce el esfuerzo de desarrollo. El incremento aporta evidencia consistente con ella: la totalidad de la funcionalidad entregada se implementó una sola vez y quedó disponible en los tres clientes, y la exportación en tres formatos se resolvió sin añadir dependencia alguna más allá de la ya autorizada.

La evaluación de seguridad, sin embargo, introduce un matiz que conviene incorporar a la discusión de la hipótesis en lugar de omitirlo. El hecho de distribuir el producto en tres clientes desde una sola base de código obligó a aplicar dos catálogos normativos distintos en lugar de uno. Es decir: el ahorro de esfuerzo se verifica en la construcción, pero no se traslada automáticamente al aseguramiento. La superficie normativa que debe evaluarse es mayor que la de una aplicación de plataforma única.

Reconocer este matiz fortalece la hipótesis en lugar de debilitarla, porque delimita su alcance con precisión. H4 se refiere al esfuerzo de desarrollo, y esa es la magnitud que el incremento respalda. Presentar el enfoque multiplataforma como una reducción de esfuerzo sin costos asociados sería una afirmación más amplia que la que los datos sostienen.

C. Sobre el significado de esta evaluación

Corresponde precisar qué se afirma y qué no con este reporte. No se afirma que BayStream sea una aplicación segura, ni que cumpla con los catálogos de OWASP. Ambas afirmaciones serían insostenibles: la aplicación carece de autenticación por decisión de alcance, y una revisión estática no basta para pronunciarse sobre el cumplimiento de un catálogo.

Lo que sí se afirma es más modesto y verificable: el estado de seguridad del producto fue evaluado contra los catálogos vigentes, los hallazgos están documentados con su evidencia y su severidad, el más grave fue mitigado dentro de lo que permite el alcance, y los restantes tienen tratamiento asignado a tareas calendarizadas. Un producto en desarrollo con una evaluación honesta y un plan de remediación se encuentra en mejor posición que uno que declara un cumplimiento no verificado.

La remediación completa —migración al proyecto de producción, autenticación real y reglas de autorización basadas en identidad—

corresponde a las tareas de cierre TC-03 y TC-04, calendarizadas del 18 al 24 de octubre de 2026. Los hallazgos de este reporte les proporcionan contenido concreto y verificable.

V. Conclusiones

El primer incremento cumplió su objetivo funcional. Los cinco elementos comprometidos del Product Backlog se entregaron completos, descompuestos en 18 tareas y 9.75 horas netas sobre una capacidad planificada de 12 horas, con siete confirmaciones del repositorio que permiten trazar cada tarea hasta su implementación. Ninguna tarea excedió el doble de su estimación y el sprint cerró sin dejar alcance pendiente.

La calidad se verificó contra un criterio fijado antes de comenzar y no ajustado después. Las seis condiciones de la Definición de Terminado se satisfacen: la suite automática pasó de 21 a 31 casos sin regresiones, el análisis estático no introdujo advertencias nuevas, las tres plataformas compilan y la validación funcional se ejecutó contra un archivo BAPLIE real de 977 contenedores. Las 49 advertencias preexistentes quedan declaradas y diferidas a TC-01, no omitidas.

La evaluación de seguridad arroja el resultado menos cómodo y, por eso mismo, el más útil. Se identificaron siete hallazgos, tres de severidad crítica o alta. El más grave no era un riesgo futuro sino una interrupción ya ocurrida: las reglas de autorización provisionales habían expirado ocho días antes de la evaluación, y la sincronización remota llevaba ese tiempo inoperante sin

producir señal alguna. Pasó inadvertido porque ninguna funcionalidad de este incremento depende de esa sincronización.

De ese episodio se desprende la conclusión de mayor valor para el proyecto. La evaluación no pudo leer las reglas vigentes porque no estaban bajo control de versiones, de modo que tuvo que inferirlas, y dos de esas inferencias resultaron falsas al contrastarlas con la consola. El primer hallazgo, la ausencia de configuración de seguridad versionada, se demostró a sí mismo: produjo exactamente el tipo de error que denunciaba. Ningún razonamiento teórico sobre la conveniencia de versionar la configuración resulta tan concluyente como esa comprobación.

Respecto de la hipótesis H4, el incremento aporta evidencia consistente: la totalidad de la funcionalidad se implementó una sola vez y quedó disponible en los tres clientes, y la exportación en tres formatos se resolvió sin añadir dependencias más allá de la única autorizada. Conviene sin embargo incorporar el matiz que la propia evaluación reveló: distribuir el producto en tres clientes obligó a aplicar dos catálogos normativos en lugar de uno. El ahorro de esfuerzo se verifica en la construcción, pero no se traslada automáticamente al aseguramiento. Reconocerlo delimita el alcance de la hipótesis en lugar de debilitarla.

Corresponde por último precisar el alcance de lo que aquí se concluye. No se afirma que BayStream sea un producto seguro ni que cumpla íntegramente los catálogos de referencia. Se afirma algo más modesto y verificable: su estado de seguridad fue evaluado contra criterios públicos, los hallazgos están documentados con su evidencia, los dos de mayor severidad quedaron

resueltos y verificados durante este mismo incremento, y los restantes tienen tratamiento asignado a tareas calendarizadas. La remediación completa corresponde a TC-03 y TC-04, del 18 al 24 de octubre de 2026.

VI. Referencias

Hernández Sampieri, R., Fernández Collado, C., & Baptista Lucio, P. (2010). Metodología de la investigación (5.^a ed.). McGraw-Hill.

OWASP Foundation. (2024). OWASP Mobile Top 10 2024 – Final release. <https://owasp.org/www-project-mobile-top-10/2023-risks/>

OWASP Foundation. (2025). OWASP Top 10:2025 – The ten most critical security risks to web applications. <https://owasp.org/Top10/2025/>

Schwaber, K., & Sutherland, J. (2020). The Scrum Guide: The definitive guide to Scrum – The rules of the game. Scrum.org.